

Controls Engagement Quick-Start Checklist

Solution Confirmation Phase Kickoff • 12-Item Pre-Flight

Card 1 / 5

KABO-TRN-CTL-TLK-001

SECTION A • PROGRAMME UNDERSTANDING (COMPLETE BEFORE FIRST CLIENT MEETING)

✓	Item	✓	Item / Notes
☐	Obtain the programme scope document <i>List of in-scope business processes, go-live dates, system landscape</i>	☐	
☐	Review the S/4HANA project charter <i>Key milestones, steering committee contacts, programme manager identity</i>	☐	
☐	Identify the system implementer (SI) <i>Name, lead contacts per workstream: functional leads, testing lead, security</i>	☐	
☐	Confirm the external auditor <i>Name of audit firm; identify the audit partner or manager on the engagement</i>	☐	
☐	Obtain current-state control documentation <i>Risk register, existing RACM, internal audit reports, prior-year management letters</i>	☐	
☐	Identify the key design decisions already made <i>Any locked scope items or design choices that cannot be changed</i>	☐	

SECTION B • STAKEHOLDER ENGAGEMENT (FIRST TWO WEEKS)

✓	Item	✓	Item / Notes
☐	Schedule kickoff with each business process team <i>P2P, O2C, RTR, HR, etc. — separate sessions per process lead</i>	☐	
☐	Prepare pain-point opening for each session <i>Research known issues before each meeting; lead with their concerns not the methodology</i>	☐	
☐	Introduce yourself to the testing lead <i>Agree on the testing captain model and how evidence requirements will be integrated</i>	☐	
☐	Set up external auditor touchpoint schedule <i>At minimum monthly; agree on what you will share and when</i>	☐	

SECTION C • RACM AND ARTEFACT SETUP (BEFORE RACM DRAFTING BEGINS)

✓	Item	✓	Item / Notes
☐	Create the initial RACM structure <i>Version 0.1: header rows, process areas,</i>	☐	

	version control tab — no content yet		
☐	Establish the artefact tracking log <i>List all programme artefacts (FDs, BPDs, config rationale) and note received vs outstanding</i>	☐	

Tip: Establish your standard evidence and deliverable approach in the first week. Apply it consistently across all business process teams from day one — inconsistency creates noise.

RACM Version Control & Traceability Log

Risk and Controls Matrix · Version History Template

Card 2 / 5

KABO-TRN-CTL-TLK-001

VERSION HISTORY LOG

Version	Date	Phase	Changed By	Change Description	Review Status
0.1	[Date]	SolCon	[Controls Lead]	Initial RACM structure — header rows and process areas. Risk universe draft.	Draft
0.2	[Date]	SolCon	[Controls Lead]	Preliminary risks added for P2P and O2C process areas. Placeholder controls.	Internal Review
1.0	[Date]	Design & Build	[Controls Lead]	First full draft — controls derived from FD review rounds 1 and 2. Business purpose and error handling sections complete.	Business Review
1.1	[Date]	Design & Build	[Controls Lead]	Updates following P2P business review: 3 controls revised; 1 new ITDM added for PR interface.	Business Review
2.0	[Date]	Testing	[Controls Lead]	Post-SIT updates: FIN-AP-001 revised following DEF-AP-001 resolution. Evidence column updated.	Internal QA
2.1	[Date]	Testing	[Controls Lead]	Post-UAT updates: ITDM controls updated with confirmed evidence reference paths.	Controls Lead
3.0	[Date]	Cutover	[Controls Lead]	Final RACM — ownership column complete. Key/non-key designation applied. Approved for go-live.	Approved

TRACEABILITY INDEX — CONTROL → RISK → RISK UNIVERSE ENTRY

Control Ref	Control Title	Risk Statement	Risk Universe Entry	FD / Artefact Source	RACM Version Added
FIN-P2P-028	PR Interface Monitoring Report Review	Incomplete/inaccurate PR transfer → off-system procurement → unrecorded liabilities	MM-P2P-R-004	FD-MM-INT-027 Section 5	v1.1
FIN-P2P-001	Three-Way Match Tolerance	Invoice mismatch > tolerance posted without block → incorrect AP balance	MM-P2P-R-001	OMR6 Config Rationale	v1.0
FIN-GL-001	Journal Entry Approval Threshold	Unauthorised JEs posted → material misstatement	GL-RTR-R-002	FD-GL-WF-014 Section 3	v1.0

Traceability principle: maintain version control from the first draft. The ability to trace from the go-live control back to the original risk universe entry is audit credibility — not optional.

Testing Evidence Requirements Specification

Per-Control-Type Evidence Standard • Positive and Negative Scenarios

Card 3 / 5

KABO-TRN-CTL-TLK-001

CONFIGURATION TESTING EVIDENCE STANDARD

Component	What to Capture	Example (three-way match)	✓ Status
01 · Navigation Path	Screenshot of the exact SPRO or transaction path taken to reach the configuration setting — not just the result screen.	SPRO → Materials Management → Logistics Invoice Verification → Invoice Block → Set Tolerance Limits	
02 · Setting Value	Screenshot showing the specific tolerance or threshold value. Must be compared against the RACM design specification.	OMR6: tolerance key B3, price variance = 2%, quantity variance = 2%. Design specified ≤3%.	
03 · Company Code Cross-Check	All relevant company codes reviewed. Any value that deviates from the standard must be investigated and either justified or corrected.	GC01–GC04: 2%. GC05: 10% — exception raised. Policy justification required before go-live.	

TRANSACTIONAL TESTING EVIDENCE STANDARD

Scenario	Purpose	Evidence Required	Test Status
POSITIVE SCENARIO	Confirms the control does NOT block valid transactions (no false positives). Test fails if a compliant transaction is blocked.	(1) Transaction execution log showing successful posting. (2) System-generated confirmation of posting document number. (3) No blocking message in the system response.	Pass / Fail / Retest
NEGATIVE SCENARIO	Confirms the control DOES block invalid transactions. This is the core evidence of control effectiveness.	(1) Transaction execution attempt log. (2) System-generated blocking message with blocking reason code. (3) Screenshot confirming no posting document was created.	Pass / Fail / Retest
DEFICIENCY NOTE	A test plan with positive scenarios only does not constitute sufficient evidence. The negative scenario is required.	If the negative scenario is missing: raise as evidence gap. Do not mark the control as tested until both scenarios are executed and evidenced.	N/A

ITDM AND MANUAL CONTROL EVIDENCE STANDARD

Element	What to Test	Evidence Required	✓
01 · IT Component	System generates the required report/output correctly and covers the right population.	System-generated report showing correct data population; reconciliation to source table confirms accuracy.	
02 · Human Component	Responsible person reviewed the output, investigated exceptions, and documented their sign-off.	Signed-off report with reviewer name and date; documented investigation notes for each exception; re-submission or escalation log where applicable.	
03 · Effectiveness	Sign-off is substantive, not perfunctory. A report signed without investigation is not evidence of an effective	Compare exception count in the report to investigation documentation. If exceptions flagged but no investigation documented: ITDM deficiency.	

	control.		
--	----------	--	--

The testing captain is your primary channel for evidence requests and re-test coordination. Set up the relationship before testing begins — not after the first inadequate evidence package arrives.

CORE STAKEHOLDER MAP

Stakeholder / Role	Contact Name	Engagement Frequency	Primary Channel	Key Topics for Controls Workstream	Status
P2P Process Lead (Client)		Weekly (Design); Bi-weekly (Test)	Working session + email	Control design sign-off; FD review outputs; evidence requirements; RACM validation	Active
RTR / GL Process Lead (Client)		Weekly (Design); Bi-weekly (Test)	Working session + email	JE approval controls; period-end controls; reconciliation sign-offs	Active
Programme Manager (SI)		Weekly	Steering committee; email	Controls integration into test cases; defect triage; go-live readiness	Active
SI Functional Lead — MM/P2P		Bi-weekly	Working session	FD review queries; interface specification; error handling gaps	Active
SI Functional Lead — FI/RTR		Bi-weekly	Working session	Configuration rationale; tolerance settings; JE workflow design	Active
Testing Captain — SIT		Daily (during SIT)	Teams/Slack + email	Evidence submission; re-test requests; SIT test case mapping	Active
Testing Captain — UAT		Daily (during UAT)	Teams/Slack + email	ITDM evidence; business user execution; UAT test case mapping	Active
External Auditor		Monthly (Design); Weekly (Cutover)	Formal meeting	RACM status; control design rationale; go-live readiness confirmation	Active
Head of Internal Controls (Client)		Monthly	Steering committee	Programme risk; control rationalization; key control designation	Escalation
CFO / Finance Director (Client)		SteerCo only	SteerCo presentation	Value delivery; programme risk; go-live readiness	SteerCo
IT Security Lead		As needed	Email	SoD matrix; access control design; security-related FD queries	As needed

Tailor every conversation to the person. The P2P business user who owns the three-way match control needs a different conversation than the external auditor who will rely on it. Translate — do not repeat.

COMMUNICATION CADENCE TEMPLATE

Activity	Frequency	Owner	Attendees	Controls Output
Controls Working Session — P2P	Weekly	Controls Lead	P2P Lead, SI MM Functional	FD review outputs; draft controls; RACM updates
Testing Evidence Review	Daily (testing)	Controls Lead	Testing Captain	Evidence log; re-test list; open items
External Auditor Update	Monthly	Controls Lead	Audit manager, programme sponsor	RACM status report; open design issues
SteerCo Controls Update	Monthly	Controls Lead	CFO, PM, SI lead	Phase progress; risks; go-live readiness

RACM Version Release	Per milestone	Controls Lead	All process leads	Approved RACM version for review
----------------------	---------------	---------------	-------------------	----------------------------------

STEP 0 · RISK FILTER — BEFORE OPENING THE DOCUMENT

?

"What risk am I trying to control?"

Define the risk type (financial · operational · regulatory) before reading. This is your filter. Assess: what could go wrong if this process or interface failed? If the failure could affect that risk — proceed to parameter extraction. If not — move on.

☐ Relevant
☐ Not relevant

FOUR-PARAMETER EXTRACTION TABLE

#	Parameter	Guiding Question + What to Look For	Your Extracted Notes
01	Business Purpose	What data transfers between which systems — and what is the business consequence if this interface fails? Connect the technical spec to the financial or operational risk. <i>FD Section 2. Note: source system, target system, data object, failure consequence.</i>	
02	Direction	Is this interface unidirectional (one way) or bidirectional (both ways)? For unidirectional: all failure detection must be at the RECEIVING system. <i>FD Section 3. Note: direction type, which system is receiving, implication for where control sits.</i>	
03	Frequency	How often does the interface run? This sets the MAXIMUM EXPOSURE WINDOW — how long errors can accumulate undetected before the monitoring cycle runs. <i>FD Section 3. Note: normal frequency, peak frequency, any manual trigger mechanism.</i>	
04	Error Handling	How does the system detect, alert on, and resolve transfer failures? This is the Controls-Critical section. Missing any component = a control gap. <i>FD Section 5 (typically). Note: detection mechanism, alert route, resolution SLA, reconciliation/sign-off requirement.</i>	

CONTROL DERIVATION OUTPUT

RACM Ref	Control Description	Control Type	Control Nature	Test Procedure Reference
		Prev / Det / Corr	Auto / Config / ITDM / Manual	

Controls-Critical: the Error Handling section (Parameter 4) is where most interface controls live. If the FD has no error handling specification — or the specification has no reconciliation/sign-off — raise it as a control gap before the design is locked.